// MLSECOPSHUB · READINESS CHECKLIST

NIST AI RMF security checklist

Framework: NIST AI Risk Management Framework 1.0 (NIST AI 100-1) and the Generative AI Profile (NIST AI 600-1)
Official source: https://doi.org/10.6028/NIST.AI.100-1
Online version and control mapping: https://mlsecopshub.com/readiness/nist-ai-rmf
Last updated 2026-09-08. 29 items. Obligations are paraphrased; engineering guidance, not legal advice.

GOVERN: policy and accountability

- [ ] Publish an AI security policy that names model supply chain, prompt injection and agent tooling as risk classes.
- [ ] Assign a named owner for AI risk and a named owner for each production model or agent.
- [ ] Record the regulatory and contractual requirements that apply to each AI system.
- [ ] Define an intake procedure for third-party models, datasets and MCP servers.
- [ ] Train engineers who handle model artifacts on safe loading and provenance verification.
- [ ] Schedule a policy review at least annually and after any AI incident.

MAP: context and inventory

- [ ] Write a system card for every deployed model and agent, including trust boundaries.
- [ ] Generate an AI-BOM in CI covering base models, adapters, datasets and external tools.
- [ ] Diagram data flows for training, retrieval and agent tool outputs.
- [ ] Enumerate threats per system using MITRE ATLAS and the OWASP Top 10 for LLM Applications.
- [ ] Document which risks are accepted, transferred or mitigated for each third-party component.

MEASURE: testing and metrics

- [ ] Scan every model artifact for unsafe serialization before it enters the registry.
- [ ] Reject pickle-based artifacts unless a documented exception exists.
- [ ] Run a prompt-injection test suite against every prompt template in CI.
- [ ] Fuzz tool and MCP schemas for parameter abuse and privilege escalation.
- [ ] Test indirect injection paths for data exfiltration.
- [ ] Define pass and fail thresholds for each security test and record results per build.
- [ ] Commission an independent red-team exercise before major releases.

MANAGE: response and monitoring

- [ ] Maintain incident playbooks for model tampering, injection compromise and rogue agent actions.
- [ ] Rehearse model rollback and tool revocation at least twice a year.
- [ ] Pin upstream model digests and verify signatures on every pull.
- [ ] Subscribe to advisories for every ML framework and serving component in use.
- [ ] Alert on anomalous prompts, unexpected tool invocations and unusual output volumes.
- [ ] Feed post-incident findings back into the threat model and test suites.

Generative AI Profile additions

- [ ] Document the provenance and licensing of every foundation model and fine-tuning dataset.
- [ ] Apply least-privilege scopes to every tool an agent can call.
- [ ] Require human approval for irreversible agent actions.
- [ ] Log full prompt and tool-call traces with retention that supports incident investigation.
- [ ] Test for confabulation in security-relevant outputs such as code and configuration.

Have this run against your pipeline: https://mlsecopshub.com/services
Book a 30-minute assessment call: https://mlsecopshub.com/contact